

Vulnerability Isolation within Nuclei

Names: Caleb Kipp, Ahmed Said, Brendan Clancy

Project Overview:

Build vulnerability templates using YAML to create more effective scans for utilization with Nuclei an open source vulnerability scanner for web addresses.

Introduction:

This project explores automated vulnerability detection using Nuclei, an open-source scanning tool known for its speed and customization. To tailor the scan results, we developed twelve custom Nuclei templates designed to filter and identify only the specific vulnerabilities we aimed to analyze. By focusing the scans through these targeted templates, the project demonstrates how customized automation can:

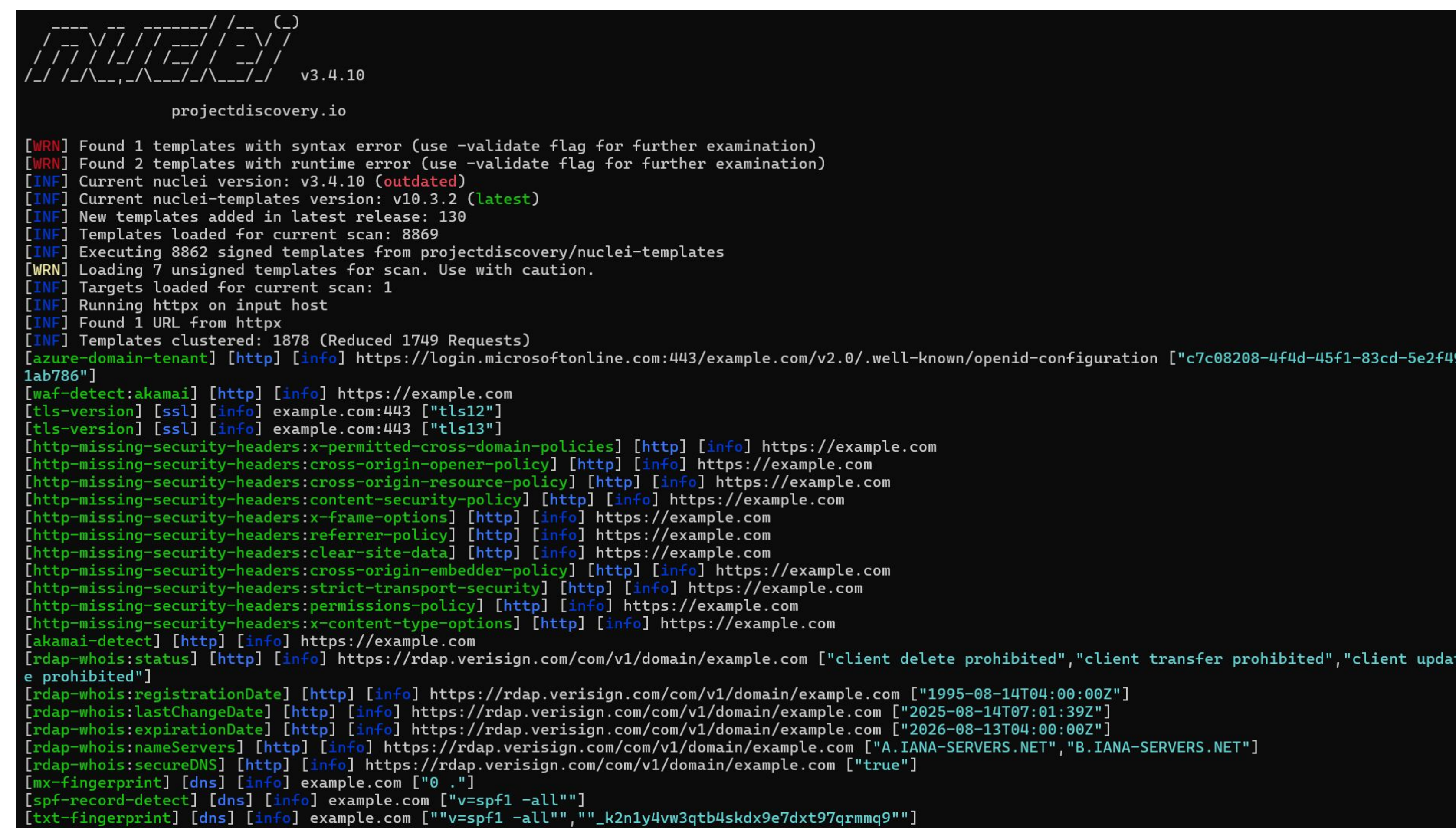
- Reduce noise.
- Improve accuracy.
- Increase Speed.
- Streamline the vulnerability assessment process.

Templates were then integrated into an AWS-based environment. This setup ensures that the client can easily view, manage, and rerun scans as needed without local configuration. By hosting everything in AWS, the project delivers a reliable tool the client can continue using long-term.

Results/Implementation:

The Problem:

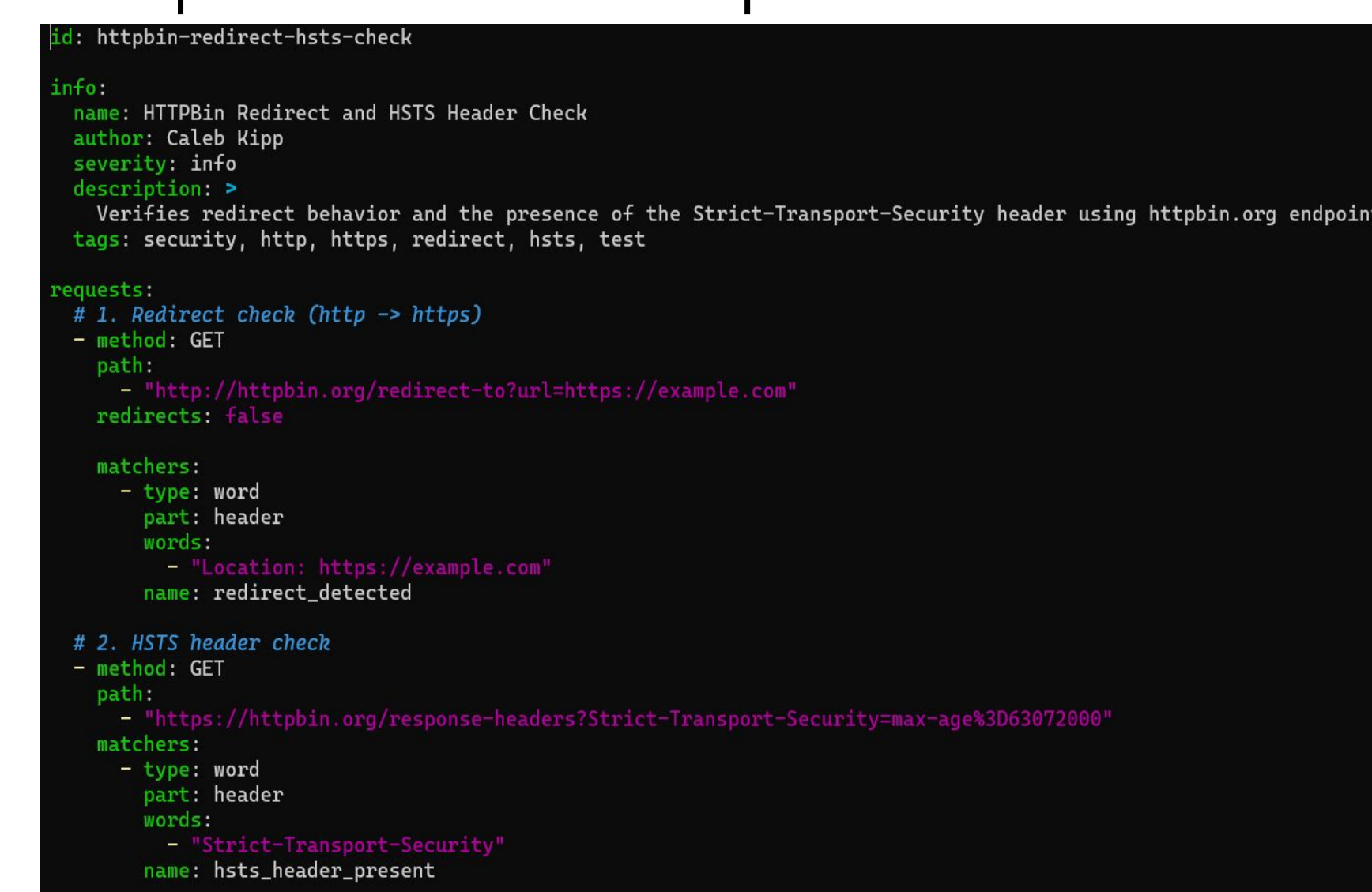
- Nuclei will scan against around eight thousand templates.
- This is slow, inefficient and will return all of the vulnerabilities.
- Output is hard to read and understand.



Http Redirect Template:

Http Redirect Template:

- Checks for https redirection.
- Verifies that HSTS is used during redirection, so data is still encrypted.

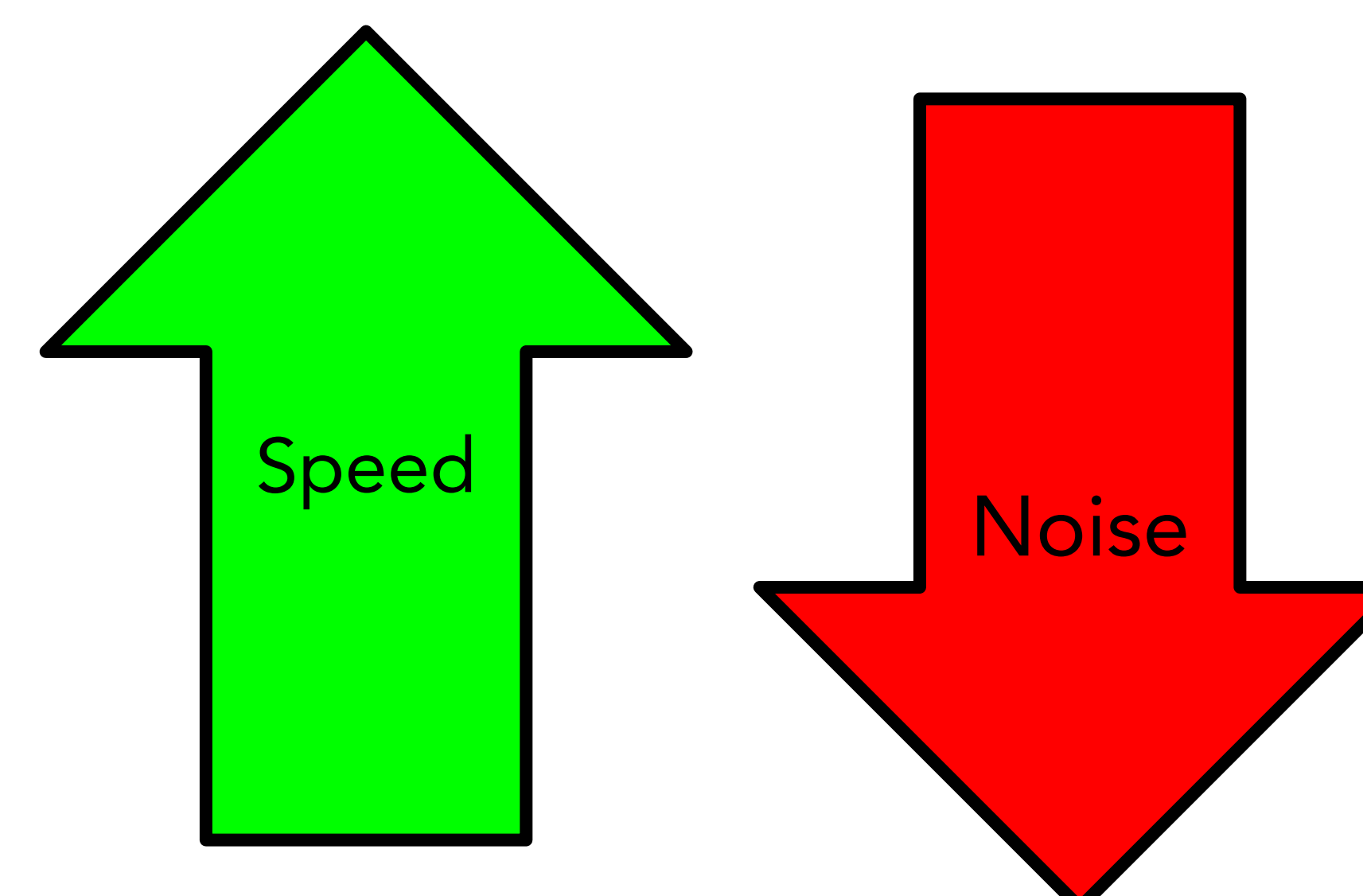


Report using http template:



The Solution:

- One template scans reduce scanning time significantly.
- Checks for an isolated vulnerability.
- Verifying http redirection can now be done efficiently.
- Output is much easier to read and understand.



Technical Details:

For our Client, we built twelve YAML templates, covering a multitude of the most common website vulnerabilities.

- ta-s3-public-and-cors template
- ta-exposed-git-and-sourcemaps template
- ta-webhook-signature-missing template
- ta-rate-limiting-missing template
- ta-cors-wildcard-cred template
- ta-http-to-http-and-hsts
- ta-missing-security-headers template
- ta-exposed-dotenv template
- ta-admin-internal-endpoints template
- ta-openai-exposed template
- ta-open-redirect template
- ta-graphql-introspection template

The templates that were made, each serving different vulnerabilities and solving the clients problem of speed and functionality.

Future Work for Client:

Building a python script that translates nuclei reports into readable reports for people not versed in nuclei.

Acknowledgements:

Special thanks to the team at Trust Anchor: Pankaj Dubey and Chintan Patel
And to our instructor for this course Vinay Bhatia